

Privacy Risk Assessment Policy

Data-use assessment

OWNER	Security & GRC
EFFECTIVE	2026-07-13
REVIEW CYCLE	Annual or material change
CLASSIFICATION	Internal

1. Purpose and scope

This policy establishes how Cobalt Harbor Systems ensures that new or changed personal-data processing is assessed before release and periodically thereafter. It applies to personnel and approved providers performing the governed activity.

2. Control objectives

Objective A. Establish accountable, repeatable operating decisions for data-use assessment.

Objective B. Produce evidence that supports independent assurance and timely remediation.

3. Required operating practices

1. Plan the activity with documented scope, owner, and timing appropriate to data-use assessment.
2. Execute and record the activity using the required evidence attributes: data flow, purpose, lawful basis, minimization decision, and mitigation owner.
3. Review exceptions and changes before they affect the control conclusion.
4. Preserve decisions and evidence in the approved repository for the stated retention period.

4. Accountability

ROLE	RESPONSIBILITY
Product owner	Carries the assigned decision, review, or recordkeeping responsibility.
Privacy counsel	Carries the assigned decision, review, or recordkeeping responsibility.
Security architect	Carries the assigned decision, review, or recordkeeping responsibility.

Data-use assessment: assurance criteria

5. Evidence standard

The accountable owner retains evidence that is sufficient to demonstrate the operating result. At minimum, each record includes: data flow, purpose, lawful basis, minimization decision, and mitigation owner. Evidence is linked to the applicable system, review period, owner, and disposition so another qualified reviewer can reproduce the conclusion.

6. Measurement and reporting

MEASURE	OPERATING THRESHOLD
Primary metric	High privacy risks have an approved mitigation plan before launch
Quality review	Evidence completeness and sampled accuracy are reviewed monthly.
Management reporting	Trends, overdue actions, and material exceptions are reported to Security & GRC.

7. Noncompliance and escalation

Unmitigated high risks require documented executive decision and re-review date The responsible owner documents the correction, root cause, and follow-up verification. Material deviations are included in the assurance register until closure.

8. Revision and approval

The policy owner reviews this policy annually, after a material control change, or following an assurance finding related to data-use assessment. Revisions must identify changed obligations, affected owners, and implementation timing before approval.

APPROVER	ROLE	STATUS
Mira Patel	Director, Security & GRC	Approved
Jonah Reed	Control Assurance Lead	Reviewed